CASE STUDY REPORT ON THREAT GROUP FIN12 ON SYDNEY VIRTUAL HOSPITAL

BY

SUSHIL ACHARYA

ARPITHA SRINIVASA MURTHY

MUHAMMAD SHERWANI

MAY 2024

Contents

1. AUTHORITY AND REVIEW..... 3
2. EXECUTIVE SUMMARY..... 4
3. TECHNICAL ANALYSIS..... 4
4. IMPACT ASSESSMENT:..... 5
4.1 Stakeholder Influence:..... 5
4.2 Social Impact:..... 6
4.3 Environmental Impact:..... 7
4.4 Economic Impact:..... 8
4.5 Ethical Impact:..... 9
5. INCIDENT COMMUNICATION AND REPORTING:..... 9
5.1. Legal and Regulatory Obligations:..... 10
6. RESPONSE..... 11
6.1 Containment..... 11
6.2 Documentation..... 13
6.3 Evidence collection and preservation..... 14
6.4 Remediation Action Plan..... 15
7. RECOVERY..... 16
7.1 Stand Down..... 18
8. LEARN AND IMPROVE..... 19
8.1 Post incident review..... 19
8.2 Update and test cyber incident response:..... 20
8.3 Training..... 21
9. PEER PARTICIPATION FORM..... 23

1. AUTHORITY AND REVIEW

Document Control and Review:

Document Control	
Author	Sushil Acharya, Arpitha Srinivasa Murthy, muhammad sherwani
Owner	Sydney virtual hospital
Date created	18/05/2024
Last reviewed by	Xu Wang
Last date reviewed	20/05/2024
Endorsed by and date	
Next review due date	

Version Control

Version	Date of Approval	Approved By	Description of Change
1.0			

2. EXECUTIVE SUMMARY

The Sydney Virtual Hospital had recently been a target of a cybersecurity incident, leading to a destructive ransomware. Initiated by the FIN12, recognised for its specialization in their malicious activities and ransomwares, they exploited financial and personal database and used them as a point of negotiations. The breach resulted in the data being encrypted by the attacker posing danger to the patient care, staff's data, and details of the further partnership that Sydney Virtual Hospital currently contains.

In response to the attack, the hospitals cybersecurity team, calmly initiated containment measure and had their best efforts to be able to recover and mitigate the impacted, various methodologies were used to ensure that the hospital is running back on their systems. The attack implications expanded immediately due casing stakeholders' impact, social impact, environmental impact, and ethical impact. However, this incident also shed light on the current security measures that must be taken by the cybersecurity team at the Sydney Virtual Hospital.

The incident underscores the ongoing threats that are faced by the healthcare providers all over Australia, requiring them ensure robust technology and cybersecurity aspect are being covered. As the healthcare facilities and the hospitals are the main targets, investing in comprehensive infrastructure and cybersecurity operations can allow the hospital to safeguard themselves in the oncoming years ahead.

In order to successfully identify and respond to the future threats, the hospital must engage their teams in further training and certifications allowing them to be proactively engaged and secure their systems in an event of the hospital being cyber attacked. This will also safeguard the hospitals reputation as being a secured healthcare facility.

3. TECHNICAL ANALYSIS

Initial Access: As found int he investigation, the attacker used a phishing email campaign as the initial access technique to access Sydney Virtual Hospital. It was done by replicating malicious files as an official document. The malicious files could be an invoice or medical reports including a code in the arbitrary background that was engaged on the first encounter where the employee opened the document file.

Lateral Movement: Multiple strategies had been used by the attacker to the further try and access the networks at the hospital to gain maximum data to gain a high ransom. Several credentials had been stolen to elevate privileges and obtain access to the most vulnerable and critical data. They also took advantage by accessing the unpatched systems. They also used PowerShell scripts which allowed them to blend in with the regular traffic.

Exfiltration: Before launching the ransomware, the attacker could have extracted sensitive data from Sydney Virtual Hospital's network in addition to encrypting it. This might contain financial

information, personally identifiable information, and medical records for the patient. The effect of the assault may be increased if the exfiltrated data was sold on dark web forums or used for future extortion.

Data Encryption: To encrypt files and data on network drives, servers, and workstations in the Sydney Virtual Hospital environment, the attacker used ransomware payloads after making a presence in the network. The ransomware blocked access to data and demanded ransom payments in return for the decryption keys using advanced encryption methods like RSA or AES.

Command and Control: While staying in control of the compromised endpoints. The attacker established a communication channel with external command and control servers during the attack, to allow them to demand for a ransom in exchange of handover the data. Their location had also been kept discreet by using anonymising services and encryption methods.

Persistence: The attacker used persistence techniques, which were mainly to control the access to the attacked network till his requirements are being met. This includes creating backdoors or a remote access trojans (RATs) on compromised devices. The attacker also changed registry entries.

Evasion: To avoid being discovered by security measures and antivirus software installed on Sydney Virtual Hospital's network, the attacker used evasion tactics. Code confusion and fileless malwares, were some of these tactics that were used by the attacker.

Evidence: IP addresses, domain names, and command and control servers were among the infrastructure pieces that forensic research uncovered as being used by FIN12. By using this data, malicious traffic may be blocked at the network perimeter and links to infrastructure used by recognised threat actors can be found.

Cybersecurity teams can learn more about the attackers' tactics and techniques by visiting the data logs in their current SIEM. This will help them plan accordingly, in the unforeseen future if there be another cyber-attack on the Sydney Virtual Hospital.

4. IMPACT ASSESSMENT:

This thorough evaluation delves into the aftermath of the attack, by FIN12 on fronts delving into the effects on the stakeholders of the hospital and the wider societal, environmental, economic, and ethical landscapes.

4.1 Stakeholder Influence:

The ransomware incident has implications for groups connected with Sydney Virtual Hospital:

- Patients: The primary and most sensitive impact is felt by patients, who could face compromised medical data. This breach could lead to identity theft, financial scams and unauthorized access to health records causing heightened anxiety and eroding trust in

healthcare privacy. Disruption in services like accessing health records and interruptions in ongoing treatments might lead to delays in healthcare delivery, potentially worsening health conditions.

- Employees: Staff members encounter disruptions. For healthcare practitioners being unable to access health records or utilize tools can impede patient care provision. Theres increased stress from managing care under compromised circumstances that can affect team morale and raise burnout levels. Administrative staff may find it challenging due to a lack of tools affecting tasks, like scheduling, billing, and communication.
- Business Associates: Suppliers and service providers connected with the hospital through shared data or integrated systems might face interruptions or their own data breaches as a result. This scenario could put a strain on relationships, lead to disagreements over contracts and cause financial setbacks for both parties involved. Investors and donors may reconsider their support due to concerns about the hospital's risk management and reputation. A reduction in funding or investments could impact expansions or enhancements.

4.2 Social Impact:

The consequences go beyond the hospital's circle.

- Public Trust and Confidence: Trust in healthcare, especially when it comes to cybersecurity measures, is vital. A breach of this scale could undermine trust not in Sydney Virtual Hospital but also in the healthcare industry. Patients might think twice about sharing information or using healthcare services, which could slow down advancements in healthcare delivery. Such a significant breach could damage confidence not in Sydney Virtual Hospital but in digital healthcare services overall. Patients might be hesitant to share health information or interact with healthcare platforms impeding the advancement of healthcare innovations.
- Reputation Damage: The negative impact on reputation resulting from a cybersecurity breach can be long lasting. It can take years for an organization to regain trust with its stakeholders, including patients, healthcare professionals and regulatory bodies. The breakdown of trust could have effects affecting the hospitals' ability to draw in patients and keep employees.
- Healthcare Accessibility: Disruption to services might push patients towards costlier alternatives like opting for in-person visits instead of digital consultations when the latter would be more suitable. This change could strain healthcare facilities. Reduce overall system efficiency.
- Financial Impact: Patients may face added expenses when seeking alternative healthcare options, such as spending on transportation for in person visits or paying out of pocket for

services not covered by insurance. This financial burden could hit low-income individuals harder. Worsen healthcare disparities.

- Community Health: On a scale compromised health data can have consequences if it leads to an uptick in healthcare fraud or misdiagnoses stemming from inaccurate or incomplete medical records. Instances of healthcare fraud might rise as cybercriminals take advantage of stolen patient data for motives. Furthermore, misdiagnoses or improper treatments resulting from compromised records may cause health outcomes for patients and undermine public health initiatives.
- Psychological Impact: The breach could also trigger effects on affected individuals causing feelings of anxiety, stress, or mistrust towards the healthcare system. Rebuilding trust within the community and addressing the impact of the situation requires communication and providing support services to those affected.
- Legal and Regulatory Consequences: Adhering to FIN12 regulations is crucial for healthcare organizations to prevent penalties and uphold trust with bodies. Failure to comply can lead to fines, legal repercussions, and harm to reputation. Therefore, it is vital to invest in cybersecurity measures, regularly assess vulnerabilities and take actions to protect patient data and ensure regulatory adherence. Dealing with the repercussions of the FIN12 incident demands a strategy that emphasizes transparency, engaging patients and implementing robust cybersecurity protocols. By restoring confidence, enhancing healthcare accessibility, and addressing community health issues hospitals can lessen the impacts of cybersecurity breaches and promote a resilient healthcare environment.

4.3 Environmental Impact:

Despite appearing minor at glance, the environmental consequences are not insignificant:

- Resource Usage: The incident escalates IT resource consumption as hospitals work to handle the crisis through data analyses, system repairs and potential hardware replacements. This spike in energy use and electronic waste adds to the hospital's impact.
- Data Center Power Consumption: During crises like FIN12 hospitals may ramp up their utilization of IT resources such as servers, data storage systems and networking devices. The growing need for processing power and storage space in data centers results in energy usage. Data centers are known for their energy consumption depending on fossil fuels for power generation, which worsens the hospitals carbon footprint. Dealing with emergencies may lead to the replacement of hardware due to system failures or upgrades resulting in the disposal of IT equipment and contributing to waste. Improper disposal of waste can cause pollution due to hazardous materials like lead, mercury and cadmium present in electronic devices. When digital systems go down the reliance on records can increase paper usage leading to deforestation and waste management issues. Operational disruptions may require transportation activities, such as courier services for transferring

documents between departments or facilities. This leads to fuel consumption and emissions further impacting the environment. Compliance with FIN12 regulations might necessitate hospitals to establish data backup and recovery procedures to safeguard information integrity and availability. These backup systems often require hardware infrastructure and energy use contributing to the impact.

- Encryption and Security Measures: Safeguarding patient information from threats involves using encryption and security measures, which may require computing resources and energy use. While essential for protecting data these steps also contribute to the environmental impact of the hospitals IT activities.
- Environmentally Friendly Procurement Practices: Hospitals can reduce their footprint by adopting eco procurement practices when acquiring IT equipment and services. This involves considering factors like energy efficiency, recyclability, and the environmental impact of suppliers. By partnering with vendors hospitals can lessen the ecological effects of their IT systems.

4.4 Economic Impact:

The financial consequences are reaching.

- Direct Expenses: These include ransom payments, costs for enhancing cybersecurity measures, hiring external experts for investigations and recovery efforts, legal expenses, and increased insurance premiums after a security breach.
- Indirect Costs: The significant lasting economic impacts could stem from revenue due to lower patient numbers, harm to the hospital's reputation and potential loss of future investments. Additionally, there might be penalties imposed by authorities if the hospital is deemed negligent in safeguarding patient data.
- Operational Effects: Disruptions to hospital operations can result in inefficiencies, heightened labor expenses from overtime work and possible revenue losses due to canceled procedures or appointments. Supply Chain Disruptions: The incident could disrupt the hospital's flow of supplies causing delays in obtaining equipment, supplies, and medications. These interruptions may impact patient care quality, raise expenses, and strain relationships with suppliers. Furthermore, supply chain disturbances can influence the economy by affecting other healthcare providers and suppliers.
- Legal Battles and Settlement Expenses: Alongside costs the hospital might encounter actions from affected patients or regulatory bodies seeking compensation for the breach. Legal disputes can lead to pressures due to settlement payouts, court fees and potential fines enforced by regulatory agencies. The uncertainty surrounding proceedings may also discourage investors and lenders, adding complexity to the hospital's financial predicament.

- Damage to Reputation and Patient Exodus: A cybersecurity breach could damage the hospital's reputation resulting in a loss of confidence and loyalty. Patients may opt for care at facilities perceived as secure causing a drop in patient numbers and revenue. Reestablishing trust with patients. The community demands investments in marketing efforts, public relations activities, and initiatives to enhance quality.
- Loss of Intellectual Property and Research Data: If the breach compromises property or research information it could deal blows to the hospital's scientific advancements and innovation capabilities. The hospital may face obstacles in developing treatments, therapies, and medical technologies due to this setback, which could hinder revenue streams and weaken its competitiveness in the healthcare sector. Employee morale and productivity could suffer because of the incident with staff members dealing with the aftermath and increased workloads during recovery. High stress levels and uncertainty may lead to absenteeism, turnover and reduced productivity impacting the hospital's efficiency and financial performance. The hospital's financial stability and ability to attract investment may be negatively affected by the breach. Investors might perceive it as an investment resulting in stock prices and challenges in accessing capital markets. Rebuilding investor trust will require communication, decisive actions and a strong commitment to cybersecurity and compliance. The breaches economic impact extends beyond the hospital to affect the community. Job losses decreased consumer spending and lower tax revenues due to the hospital's troubles can have repercussions on businesses, service providers and government budgets. Collaborative efforts involving the hospital, local authorities and economic development organizations may be needed to address these effects and support community resilience.

4.5 Ethical Impact:

Addressing the aspects poses a challenge.

- Decision Making: The dilemma of whether to pay the ransom involves balancing the urgent need to resume services with the moral implications of supporting criminal organizations. Additionally, how the hospital manages the breach its openness with stakeholders and efforts to minimize harm reflect its position.
- Answerability: Safeguarding patient data is an obligation. The breach raises concerns about choices regarding cybersecurity investments and the effectiveness of measures. It also assesses the hospital's responsibility, in handling repercussions and preventing occurrences.

5. INCIDENT COMMUNICATION AND REPORTING:

Effective communication and reporting of incidents play a role in adhering to FIN12 regulations, which demand the transparent disclosure of cybersecurity events in the healthcare industry. FIN12 aims to strengthen the resilience of healthcare entities against cyber threats highlighting

the significance of communication to mitigate the impact of security breaches on care, privacy, and organizational reputation. When faced with a cybersecurity incident healthcare organization should implement an incident response strategy that includes defined communication protocols. This strategy should clarify the roles and responsibilities of stakeholders, establish channels for both external communication and outline procedures for assessing, containing, and resolving the incident. By having a structured incident response plan in place organizations can streamline their communication efforts and reduce the risk of confusion or misinformation during crisis situations. Furthermore, it is essential for healthcare organizations to communicate openly and transparently with affected individuals such as patients, employees and partners regarding the nature and extent of the incident as any potential risks or implications involved. Clear and concise communication fosters. Credibility among stakeholders while showcasing a dedication to transparency and accountability when addressing cybersecurity challenges. In summary compliance with FIN12 necessitates that healthcare organizations prioritize incident communication practices along with reporting mechanisms. By being transparent, about cybersecurity incidents collaborating with bodies and stakeholders and promoting a culture of openness and teamwork healthcare organizations can reduce the effects of security breaches ensure patient confidentiality and maintain the reliability of healthcare systems and services.

5.1. Legal and Regulatory Obligations:

Following the FIN12 guidelines healthcare institutions need to inform regulatory bodies about cybersecurity incidents. In Australia these organizations operate within a framework overseen by entities like the Office of the Australian Information Commissioner (OAIC) which enforces privacy laws outlined in the Privacy Act 1988 and Australian Privacy Principles (APPs). The Australian Digital Health Agency (ADHA) oversees the My Health Record Systems cybersecurity integrity. While the Australian Cyber Security Centre (ACSC) provides advice on cybersecurity issues healthcare organizations must comply with the Notifiable Data Breaches (NDB) Scheme that requires reporting data breaches that may lead to harm. Furthermore, some states and territories have their health privacy laws such as the Health Records and Information Privacy Act (HRIPA). Adhering to these regulations involves implementing cybersecurity practices promptly reporting incidents and following data protection standards to protect patient privacy and meet requirements. This requirement for reporting ensures that regulatory bodies are notified about security breaches that impact protected health information (PHI) enabling them to take steps to protect patient privacy and uphold compliance with data protection laws. Sydney Virtual Hospital faces the challenge of navigating through frameworks:

- Breach Notification: Regulations mandate reporting to authorities and affected individuals outlining the compromised data, potential risks to those impacted and actions taken to secure the systems.
- Compliance: The hospital must adhere to international data protection regulations, which may involve audits and ongoing reporting on the aftermath of the breach and efforts for mitigation.

- Communications: Apart from communication, emphasis is placed on internal communication within healthcare organizations by FIN12. This ensures that all staff members understand their roles in responding to a cybersecurity incident. Regular updates and briefings should be provided to departments and personnel regarding incident status, mitigation efforts, policy changes or procedural updates.

In terms of communication strategy:

i. Transparency: Informing staff at all levels fosters an environmentally critical, for effective incident management.

ii. Maintaining integrity and morale is key.

- Guidance: It is important to give instructions on how to talk about the incident, with the public to protect the hospital from issues and avoid spreading misinformation.
- External Communications: Dealing with communication involves handling relationships with outside parties.
- Patients and General Public: Making sure that communications are compassionate, easy to understand and based on facts helps maintain trust and gives assurance that the hospital is managing the situation responsibly.
- Media Relations: Actively engaging with the media assists in controlling the story, preventing alarm, and explaining the steps being taken to address the crisis and prevent incidents in the future.

6. RESPONSE

6.1 Containment

Security is crucial when facing risks like ransomware, as demonstrated by the actions of threat groups, like FIN12. Containment includes isolating and minimizing the consequences of a security breach to reduce its impact and harm. Some of the containment actions to be considered for Sydney Virtual Hospital includes:

- Identification of impacts to the system or services:

Assess the consequences or effects of containment measures on other systems or services. For instance, isolating a section of the network to control ransomware might cause an interruption in network activities or essential services. Finding the balance between containment and minimizing disruptions is vital to ensuring hospital operations.

- Time and Resource requirement:

Evaluate the time and resources required to put containment measures in place. This involves deploying security tools and isolating impacted systems by collaborating with technical teams, external partners and keeping stakeholders informed. Acting swiftly to contain the situation is crucial to stop the incident from spreading.

- Effectiveness of containment solutions:

Decide how much containment is necessary depending on how severe the FIN12 ransomware is. This might involve isolating systems or sections to completely isolating the network. The containment strategies should match the level of threat and the possible consequences. This can be partial or full containment of hospital resources as mentioned below.

Partial Containment:

During containment, certain systems or sections impacted by a security breach are isolated, keeping areas functioning normally. This method aims to limit disruptions to business operations concentrate on fixing the issues and lower the chances of harm. However, it is crucial to pinpoint the affected system and maintain surveillance to hinder attackers from moving laterally.

Full Containment:

Isolating networks or environments for containment is a comprehensive strategy to halt the spread of threats. Although it effectively prevents compromises and data loss, this approach can cause business disruptions. To mitigate downtime thorough planning and clear communication are essential.

- Containment solutions: Consider whether the measures will be long-term or lasting depending on the situation and risk evaluation. Short term fixes to be adopted by Sydney Virtual Hospitals' security team might involve isolating affected systems until they are fixed, while permanent solutions could entail making enduring adjustments, to network structure, access permissions or security protocols to avoid similar incidents in the future. Temporary Containment: Short-term containment strategies are put in place as responses to address the effects of a security breach. These measures aim to isolate affected systems or areas to halt the spread of the incident. Common actions include segmenting networks or implementing temporary access restrictions to contain the threat promptly. The objective is to restore

operations while more long-lasting remedial steps are planned and implemented. Short term containment provides advantages such as mitigation to minimize disruptions to business functions and reduce downtime. However, they need evaluation and adjustments, for continued effectiveness. This should be followed by thorough incident analysis and permanent preventive measures to avoid future incidents.

Permanent Containment: Long-term solutions for containment are methods put in place to prevent incidents from happening again. These solutions focus on addressing weaknesses, enhancing security measures, and establishing controls. They include modifying network structures, access regulations, security protocols and threat detection capabilities to enhance cybersecurity defenses. By mitigating risks permanent containment provides enduring protection and improves the organization's ability to detect respond to and recover from security breaches efficiently. However, implementing these solutions necessitates thorough planning, resource allocation and support from stakeholders. Regular updates and reviews are also essential to keep up with changing threats and business requirements. Combining both permanent containment strategies is vital for handling security incidents and safeguarding organizational assets against evolving threats over the long haul.

6.2 Documentation

In incident management, documenting the incident helps in keeping a detailed record of incident from its start to end. This is important for having a picture of the ransomware timeline and the steps that were taken. It plays a role in refining responses and boosting cybersecurity readiness overall. The following points should be clearly stated while preparing the response documentation.

- Incident date and time: The FIN 12 threat group is a financially motivated group, and its ransomware activity has been ongoing since October 2018 with activity observed through the first half of 2021. We can possibly assume the date and time for the ransomware attack on Sydney Virtual Hospital during that period.
- Current Status of the Incident: The incident remains active and ongoing with a growing variety of access points being utilized.
- Incident Type and Classification: Cybercriminals have launched attacks specifically attributed to the motivated threat actor group FIN12. The attacks primarily target the

healthcare sector with 20% of victims being care facilities. Other sectors affected include business services, education, finance, government, manufacturing, retail, and technology. The geographical impact of these attacks is mainly concentrated in North America accounting for 85% of victims. However, there have been instances reported in countries, like Australia, Colombia, France, Indonesia, Ireland, the Philippines, South Korea, Spain, the UAE, and the UK.

- Severity: The severity of these attacks is deemed high as they result in disruptions to healthcare services and other critical sectors. The threat actors also pose a risk of demanding sums from targeted high revenue organizations like Sydney Virtual Hospital.
- External Assistance: To tackle this ransomware external assistance is necessary. Sydney Hospital can collaborate with cybersecurity firms such as Mandiant for threat intelligence has proven beneficial. Additionally, seeking support from law enforcement agencies is crucial given the severity and widespread nature of these attacks.
- Resolution of Incident: Efforts to address and resolve these incidents include Mandiant Intelligences release of a report outlining FIN12s activities. The establishment of VHR20210922 – FIN12 by Mandiant Security Validation Behavior Research Team aims at enhancing security measures through monitoring and updating of threat intelligence and the hospital can also adopt similar measures.

6.3 Evidence collection and preservation

Ensuring evidence is properly collected and preserved is crucial in managing incidents in cybersecurity cases such as those related to FIN12. The correct handling of evidence is essential for its use in investigations and legal processes. Some of the ransomware collection and preservation for FIN12 incident:

- Network Traffic and Logs: It is important to gather and safeguard network traffic information and logs that may reveal how FIN12 initially gained access and moved around within the network.
- Malware Samples: Securely acquiring and storing samples of other software utilized by FIN12 like TRICKBOT and BAZARLOADER is crucial.

- Affected Systems: Making copies of impacted systems is essential, for studying the deployment and identifying any related backdoors or droppers.
- Communications: Keeping records of all communications, such as ransom notes or emails can offer insights into the attackers' demands and strategies.

By adhering to these instructions Sydney Virtual Hospital can ensure they handle evidence correctly during a cybersecurity incident leading to a response that supports investigations or legal proceedings.

6.4 Remediation Action Plan

The plan to tackle ransomware by the threat group FIN12 focuses on removing the threat while minimizing disruptions to essential operations. Initially the priority is to contain the situation by isolating infected systems and disabling any user accounts. The next step involves eliminating the related malware like TRICKBOT and BAZARLOADER from affected systems through scanning and patching vulnerabilities.

After that, restoration includes recovering systems from backups ensuring data integrity before reconnecting them to the network. Validation is crucial for confirming the removal of threats by conducting system scans and monitoring for any signs of reinfection. The incident response involves teams such as IT administrators, network experts and SOC analysts.

Furthermore, it may be essential to utilize resources, such as cybersecurity companies for in depth threat analysis and investigative work well as law enforcement agencies for potential legal measures and collaboration. The responsibility for addressing actions is divided among multiple parties. The Incident Response Lead oversees the planning and execution process, IT and network administrators manage tasks like isolation, patching and system recovery security analysts concentrate on identifying threats and eliminating them while external cybersecurity professionals offer advanced forensic analysis and guidance.

Prioritizing systems and services during the remediation process is critical. Vital healthcare systems like Electronic Health Records (EHR) and medical devices supporting patient care take precedence along with hospital systems such as platforms, billing systems and customer service portals. Network components such as firewalls, routers, switches, and email servers also require attention. Throughout the remediation phase isolated systems may be temporarily offline for

cleaning and verification purposes and certain network segments might be isolated to prevent spread which could limit access to resources within the network. Backup procedures may lead to performance or temporary unavailability of systems during restoration operations.

The estimated time for resolution includes containment after detecting the incident elimination within 1 to 3 days depending on the severity of the infection and recovery of critical systems within 3 to 5 days with complete system restoration and verification potentially taking up to a week. The detailed steps for remediation commence with an analysis to assess the impact of the infection and allocate resources to teams accordingly reaching out to external support if necessary.

By adhering to this Remediation Action Plan, the hospital can effectively manage the FIN12 ransomware incident, minimize its impact, restore operations, and fortify its defenses against future cyber threats.

7. RECOVERY

Recovering from a FIN12 attack involves the restoration of impacted systems and data using verified backups. It is crucial to ensure that all restored systems are free of malware and fully operational. The recovery process gives priority to healthcare systems, like Electronic Health Records (EHR) and medical devices along with hospital systems such as financial and billing platforms. It is important to verify the integrity and security of the restored data before reconnecting the systems to the network. Continuous monitoring is put in place to detect any signs of reinfection or unusual activity allowing the Sydney Virtual Hospital to safely and effectively resume operations. The Recovery plan for the affected system by FIN12 ransomware incident includes the following:

- Restoration of systems to normal operation:
- Prioritization: Identify the systems impacted by the FIN12 incident for keeping the business running smoothly.
- Backup Recovery: Retrieve settings from backups that have been checked for accuracy to reduce any downtime.
- Gradual Recovery: Implement the recovery process in stages beginning with functions and gradually adding elements once they've been confirmed.

- Testing Phase: Carry out testing and validation of restored systems to ensure they operate as expected and meet performance standards.
- User Trainings: Offer tailored training to users on the systems and security measures to help them transition back to operations seamlessly.
- Estimated Timelines: Clearly define and share anticipated timelines for system recovery balancing speed with thoroughness to minimize disruptions in operations.

- Monitoring the system:
- Implementing Ongoing Monitoring: Utilize tools for monitoring to detect any remaining threats or unusual activities after the recovery process with a focus on observing network traffic patterns and system behaviors.
- Strengthened Security Measures: Enhance security measures by bolstering Intrusion Detection Systems (IDS) endpoint protection solutions and access controls to prevent any re attempts and unauthorized access incidents.
- Preparedness for Incident Response: Maintain an approach to incident response readiness in order to promptly address any security incidents or abnormalities identified during the monitoring phase.
- Regular Security Assessments: The hospital must conduct regular security audits and equipment health checkups to assess the effectiveness of recovery actions and ensure compliance with security policies and industry standards.

- Management of vulnerabilities
- Vulnerability Assessment: Regularly conduct vulnerability assessments and penetration testing to pinpoint and prioritize vulnerabilities in networks that were compromised during the FIN12 incident.
- Patch Management: Establish a process for patch management to promptly apply security patches and updates addressing vulnerabilities exploited by FIN12.
- Threat Intelligence Integration: Keep abreast of threat intelligence pertaining to FIN12 tactics and tools in order to proactively tackle emerging vulnerabilities and threats.

- Risk Mitigation: Create and put into action risk mitigation strategies for identified vulnerabilities, such as network segmentation, access controls and system hardening measures.
- Continuous Improvement: Continuously enhance vulnerability management processes based on insights, from incidents, industry standards and the changing landscape of threats.

By implementing this specialized recovery strategy for the FIN12 incident, hospital can successfully recover affected systems maintain security monitoring and take steps to address vulnerabilities and reduce the likelihood of similar incidents occurring again in the future.

7.1 Stand Down

After dealing with the cyber threat, from FIN12 and successfully handling the attack a "stand down" phase is initiated. This phase comes all necessary steps like containment, eradication and recovery have been completed in response to the incident involving FIN12. Here's how a stand down fits into the incident response strategy for dealing with FIN12:

- Wrap Up of Immediate Tasks: Once the ransomware attack by FIN12 has been contained and eliminated tasks such as isolating affected systems recovering data from backups and enhancing security measures are finalized by the incident response team.
- Evaluation and Reflection: During the stand down period there is an assessment of how effective the response to the FIN12 incident was. This evaluation looks into how systems were impacted, data integrity was maintained, and business operations were affected. The analysis post incident aims at identifying tactics used by FIN12 to enhance detection and response capabilities.
- Ongoing Monitoring: Continuous monitoring of systems is crucial to detect any remaining threats or potential reinfection, by FIN12 or threat actors. This vigilance is essential to ensure that all traces of ransomware are eliminated and there are no lingering threats left behind.
- Documentation and Reporting: During the stand down period, after the FIN12 incident a detailed record of the response process, actions taken, outcomes and key learnings is compiled. This information is used to create an incident report that outlines the timeline of events, analyzes the impact, suggests ways to mitigate incidents and provides recommendations for strengthening cybersecurity defenses.

- Preparation for incidents in future: As part of the stand down phase, training sessions and knowledge sharing activities may be conducted to enhance incident response skills, share insights on FIN12s tactics and raise awareness about cybersecurity among team members and relevant stakeholders.

Throughout the stand down phase clear communication is maintained with leadership IT teams and external partners to keep them updated on the incident progress. Closure of the response process. This ensures that stakeholders are well informed and have confidence in the organization's ability to manage incidents in the future. The stand-down phase following a FIN12 incident response is a time for reflecting, learning, and enhancing cybersecurity defenses, which helps bolster the organization's resilience against threats.

8. LEARN AND IMPROVE

8.1 Post incident review

Post Incident Review (PIR) of the Ransomware Attack at Sydney Virtual Hospital will look into the depth of the attack and focus on the measures that were taken for the cyber attackers to be successful accessing the data and services of Sydney Virtual Hospital.

1. **Analysis of Main Causes:** A ransomware attack was the reason behind the network infrastructure and security was breached by an attacker. The attackers used the weaknesses that are encompassed by the Sydney Virtual Hospital currently. The attacker took that to his advantage and enabled the ransomware via unauthorised access and installed the ransomware. The attack severance was increased due to the negligence of the employees on site unable to understand the attack. This could be controlled by correct trainings and information being provided to the employees.

2. **Initiative-taking steps** such as friendly phishing and vulnerability assessment should be used in order to ensure the necessary security measures are being covered. Employee training will also play an essential role, such as training programs different security measures that can be implemented by the employees to reduce the chances of data breaches. Strong access control can also be used to ensure privilege access is being implemented.

3. **The first point of contact** teams is expected to manage the ransomware attack promptly and they should communicate the information to the higher authorities allowing them to take all the necessary actions to stop the attacker from gaining access. The early identification process did reduce the attacker to spread of his reach onto other business databases. The effective mobilisation of resources was facilitated by adherence to established incident response protocols and escalation processes.

4. **Strengthening the network** security protocols with routine penetration tests and routine software and systems updates and patches will reduce the vulnerabilities by heaps allowing the threat actors like the ransomware attackers to have low chances of gaining access to the critical systems and information's. It is also important to train the employees with the oncoming updates with the system that may allow Sydney Virtual Hospital to streamline future attacks.

Sydney Virtual Hospital may improve resistance against ransomware attacks such as FIN12 and fortify its cybersecurity posture by conducting a comprehensive PIR and putting suggestions into practice. Cyber incidence response plan should be updated on a regular basis and all the changes and attacks should be documented. Appropriate staff and stakeholders should be notified of the changes, while conducting friendly the phishing and malware attacks.

8.2 Update and test cyber incident response:

To improve the hospital's preparedness to manage future events successfully, the Cyber Incident Response Plan (CIRP) must be updated and evaluated in the wake of the Post Incident Review (PIR) that was conducted following the ransomware assault on Sydney Virtual Hospital by FIN12. For the update and testing procedure, follow these guidelines:

1. **Identification of Changes:** Examine the PIR's conclusions and suggestions to determine what changes to the CIRP are required, such as adjustments to protocols, roles, responsibilities, and escalation routes.

2. **Updated Documentation:** Make sure that the revised playbooks, processes, and templates are accurate and clear by documenting all modifications to the CIRP that have been found.

3. **Communication:** Make sure that all pertinent staff members and stakeholders at Sydney Virtual Hospital are aware of the updated CIRP, playbooks, and templates. Make certain that everyone is aware of their obligations in the case of a cyber incident.

4. **Training and Awareness:** To acquaint response teams and important stakeholders with the revised CIRP, undertake training sessions and awareness campaigns. Give instructions on how to successfully adopt the updated processes.

5. **Testing and Validation:** Schedule periodical tabletop exercises or simulated incident scenarios to assess the effectiveness of the modified CIRP. Analyse team responses, spot any holes or potential areas for development, and include suggestions for future plan revisions.

6. **Documentation of Test Results:** Record the findings from the validation and testing processes, together with any lessons discovered and suggestions for additional CIRP enhancements.

7. **Continuous Improvement:** Create a procedure for the regular evaluation and improvement of the CIRP in light of new risks, evolving technological capabilities, and insights gained from testing exercises and real-world occurrences.

Sydney Virtual Hospital can improve its capacity to identify, respond to, and recover from cyber events, minimising the impact on operations and guaranteeing the protection of sensitive patient data, by updating and evaluating the Cyber Incident accordance Plan in accordance with the PIR's findings.

8.3 Training

Comprehensive training programs and required to improve the incidence response and to reduce the chances for a potential hacker to gain access to the Sydney Virtual Hospital's Virtual databases and systems. These are the proposed training programs for the employees at the hospital:

1. **Incident response training:** Specialise the team in understanding potential malware and phasing attacks.
    - Training on understanding and analysing anonyms activities in their network, suspicious behaviour, and an indication of comprise (IOC).
    - Developing activities to understand the malware, educating the team on how malware can affect and what it potentially acts like. As well as a visual representation of what malware can look like.
    - Recovery and restoration, inform the employees of your potential recovery plan so that they understand the complexity of the attack and know to be patient, while the recovery process is on the way.
    - Post incident procedures, the employees should know the initial steps to that are to be taken by them after a potential attack. E.g. further securing their devices and accounts.

2. **Hands-on Exercising:** Replicating a virtual cyber-attack is an effective way of understating the vulnerabilities and the employees must know and understand how a system/device tends to work while it is under attack. The situations of the replicated attack must be as close to reality as they can be, so the employees take it as their responsibility to stay cyber safe.

3. **Provide cyber awareness training:** On the other hand, the stakeholders (patients and partners) need to be advised on the ongoing situations to ensure they are not entering their data/details into a phishing website assuming that it is legitimate.

4. **Technical Training:** Provide the IT and cyber security teams with technical training courses that are focused on the trends of the attacks, and they are up to date with the information and steps that need to be taken in case of a potential cyber-attack. The IT and cyber teams should be trained on, basic network security such as endpoint security, intrusion prevention systems and firewalls, they should also be shown the tools that are used to actively monitor all the hospital systems and databases. In order for them to learn the tools and cyber secure environments, they should be going for various different certifications, such as Certified Information Systems Security Professional (CISSP), Certified Incident Handler (GCIH), Certified Information Security Auditor (CISA) etc.

5. **Encourage participation:** Encourage the team to attend the workshops by providing them incentives, which are to be discussed by the Sydney Virtual Hospitals management and create social groups and gatherings in order to educate the staff.

By investing in these critical trainings Sydney Virtual Hospital can have a team that is empowered to understand and reduce the chances of unauthorised access to their systems. These skills in the will also allow the Sydney Virtual hospital to safeguard them from future attacks and protect.